

Informe de auditoría del ENS de los sistemas de información que soportan el servicio Azure de Microsoft

Microsoft Corporation

22/04/2024

Documento de uso interno



Microsoft Corporation

INFORME DE AUDITORÍA DEL ESQUEMA NACIONAL DE SEGURIDAD DE LOS SISTEMAS DE
INFORMACIÓN QUE SOPORTAN EL SERVICIO AZURE DE MICROSOFT

(Basado en el Real Decreto 311/2022, del 3 de mayo)

Índice

1.	INFORME DE AUDITORÍA.....	2
1.1.	Introducción.....	2
1.2.	Objetivo.....	2
1.3.	Alcance.....	3
1.4.	Equipo Auditor.....	4
1.5.	Fechas de Auditoria	4
1.6.	Metodología	5
1.7.	Conclusiones	5
2.	RESUMEN DE LAS MEDIDAS DE SEGURIDAD.....	8

Microsoft Corporation

INFORME DE AUDITORÍA DEL ESQUEMA NACIONAL DE SEGURIDAD DE LOS SISTEMAS DE INFORMACIÓN QUE SOPORTAN EL SERVICIO DE AZURE DE MICROSOFT

(Basado en el Real Decreto 311/2022, del 3 de mayo)

1. INFORME DE AUDITORÍA

1.1. INTRODUCCIÓN

De acuerdo con los términos de nuestra propuesta de servicios profesionales, les presentamos nuestro informe de auditoría del Esquema Nacional de Seguridad, de categoría Alta de los Sistemas de Información que soportan el servicio Azure de Microsoft, de acuerdo con lo previsto en el artículo 31 y en el anexo III del Real Decreto 311/2022, del 3 de mayo.

Este informe de auditoría ha sido preparado para uso exclusivo de Microsoft Corporation (en adelante Microsoft o la Organización), situado en One Microsoft Way, Redmond, WA 98052-6399 (Estados Unidos), en el contexto de la revisión de cumplimiento de los requerimientos del Esquema Nacional de Seguridad de categoría Alta, por lo que no deberá ser utilizado para fines distintos al descrito a continuación ni ser distribuido a terceros, salvo requerimiento de la autoridad competente.

1.2. OBJETIVO

Para cumplir con la normativa vigente, y de conformidad con el artículo 31 y con el Anexo III del Real Decreto 311/2022, hemos procedido, a solicitud de Microsoft, a revisar el cumplimiento de los requisitos de categoría Alta establecidos en el Real Decreto 311/2022, del 3 de mayo, que regula el Marco de Seguridad Nacional en los capítulos II y III y en los anexos I y II.

Nuestra responsabilidad es la emisión de un informe que exprese una opinión sobre la idoneidad de los sistemas que soportan el servicio Azure de Microsoft, a las medidas y controles definidos de categoría Alta en el Esquema Nacional de Seguridad. Adicionalmente, nuestro informe a categoría Alta incluye los datos, hechos y aspectos en que se basan los dictámenes alcanzados.

1.3. ALCANCE

El alcance de la auditoría incluye los servicios y la infraestructura que componen el servicio Azure de Microsoft:

- Azure Confidential Computing
- Microsoft Entra (incluye Entra ID, Entra ID Governance, Entra External ID, Entra Domain Services, Entra Verified ID, Entra Permissions Management, Entra Workload ID, Entra Internet Access y Entra Private Access)
- Azure Site Recovery
- Azure Virtual Network
- Azure ExpressRoute
- Azure Load Balancer
- Azure Backup
- Azure AI Services (incluye Azure OpenAI, Azure Cognitive Search, Azure AI Vision, Azure AI Custom Vision, Azure AI Language, Azure AI Speech, Azure AI Translator, Azure AI Document Intelligence, Azure AI Bot Service, Azure AI Audio & Video, Azure AI Anomaly Detector, Azure AI Content Safety, Azure AI Personalizer, Azure AI Metrics Advisor y Azure AI Immersive Reader)
- Azure AI Studio (incluye Azure OpenAI Studio, Azure Machine Learning Studio, Azure Language Studio, Azure Speech Studio, Azure Vision Studio, Azure Custom Translator Studio, Azure Document Intelligent Studio y Azure Content Safety Studio)
- Microsoft Copilot for Azure
- Azure SQL
- Azure Cosmos DB
- Azure SQL Database
- Azure Database for PostgreSQL
- Azure SQL Managed Instance
- Azure Database for MySQL
- Azure Cache for Redis
- Azure Database for MariaDB
- Azure Storage (incluye Blob, Archive, Disk, File y Data Box)
- Azure Synapse Analytics
- Azure Databricks
- Azure Data Factory
- Azure HDInsight
- Azure Analysis Services
- Azure Data Lake
- Azure Data Lake Analytics
- Microsoft Fabric
- Fabric Copilot
- Power BI Embedded
- Azure DevOps
- Azure IoT Hub
- Azure Event Hubs
- Azure Log Analytics
- Azure Monitor
- Azure Key Vault (incluye Standard, Premium y Managed HSM)
- Microsoft Sentinel
- Microsoft Copilot for Security
- Microsoft Defender for IoT
- Microsoft Defender for Cloud
- Microsoft Defender Cloud Security Posture Management
- Microsoft Defender External Attack Surface Management (EASM)
- Azure DDOS Protection
- Azure Firewall
- Azure Firewall Manager
- Azure Web Application Firewall
- Azure Application Gateway
- Azure VPN Gateway
- Azure Bastion
- Azure Virtual Machines
- Azure Kubernetes Service
- Azure Container Instances
- Azure Container Registry
- Azure Containers Apps
- Azure App Service
- Azure Web Apps
- Azure Logic Apps
- Azure API Management
- Azure Service Bus
- Azure Event Grid
- Azure VMware Solution
- Azure Virtual Desktop (AVD)
- Azure Arc

En el alcance de la presente auditoría se ha tenido en consideración los siguientes centros de datos propios y externalizados en las siguientes regiones:

- Centro-oeste de Alemania - Frankfurt (Alemania)
- Centro de Alemania - Frankfurt (Alemania)
- Norte de Alemania - Berlín (Alemania)
- Noreste de Alemania - Leipzig-Halle (Alemania)

- Norte de Europa - Dublín (Irlanda)
- Oeste de Europa - Ámsterdam (Países Bajos)
- Centro de Francia - París (Francia)
- Sur de Francia - Marsella (Francia)
- Este de Noruega - Oslo (Noruega)
- Oeste de Noruega - Stavanger (Noruega)
- Centro de Suecia - Gävle, Sandviken, Staffanstorp (Suecia)
- Oeste de Reino Unido - Cardiff (Reino Unido)
- Sur de Reino Unido - Londres (Reino Unido)
- Oeste de Suiza - Ginebra (Suiza)
- Norte de Suiza - Zúrich (Suiza)
- Centro de España - Madrid (España)
- Italia Norte - Milán (Italia)
- Polonia Central - Varsovia (Polonia)
- Este de Austria - Viena (Austria)
- Centro de Finlandia - Helsinki (Finlandia)

El alcance de la revisión ha contemplado los elementos necesarios para el desarrollo de los Sistemas de la Organización de acuerdo con la Declaración de Aplicabilidad “Microsoft_ENS_SOA.xlsx”

CATEGORÍA	CONFIDENCIALIDAD	INTEGRIDAD	TRACEABILIDAD	AUTENTICIDAD	DISPONIBILIDAD	Total de requerimientos
	ALTA	ALTA	ALTA	ALTA	ALTA	71

A continuación, se enumera el detalle de los requisitos completos que no forman parte del alcance de la revisión:

- **Marco operacional: Recursos externos**
 - op.ext.4 - Interconexión de sistemas
- **Medidas de protección: Protección de la información**
 - mp.info.3 - Firma electrónica

1.4. EQUIPO AUDITOR

A continuación, se indican los componentes del equipo responsable de la auditoría, así como su función:

EQUIPO AUDITOR	
Roger Pérez	Auditor jefe
Samir Kamal	Auditor
Helios Gómez	Auditor

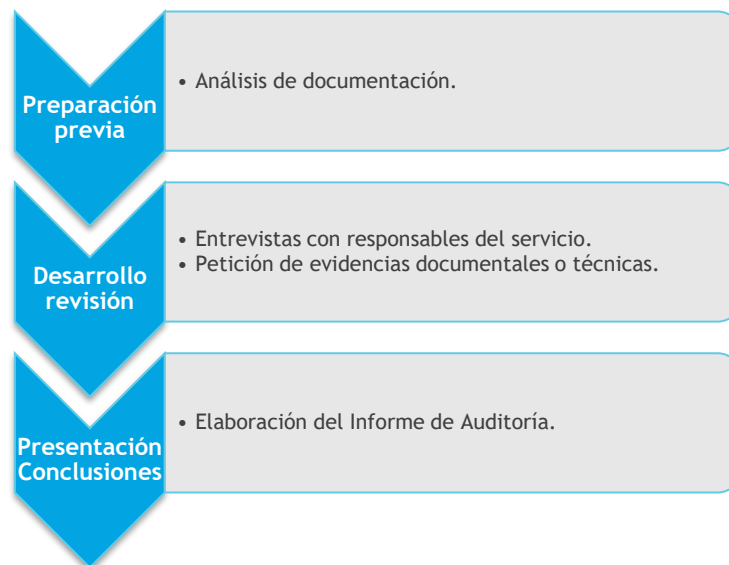
1.5. FECHAS DE AUDITORIA

Fecha de realización de la auditoria:

- **Auditoria documental:** del 1 de marzo al 1 de abril de 2024.
- **Entrevistas:** del 1 de marzo al 12 de abril de 2024.

1.6. METODOLOGÍA

La metodología empleada para la realización del presente trabajo ha consistido en:



- **Preparación previa:** el trabajo de revisión se ha iniciado con un análisis de la documentación facilitada por la Organización, a partir de la que se ha planificado la revisión juntamente con los responsables del proyecto de la Organización.
- **Desarrollo de la revisión:** se han validado los procedimientos descritos y se han realizado las pruebas y comprobaciones necesarias para asegurar que se adecuan a la normativa vigente.
- **Entrevistas:** las personas de BDO que han participado en la revisión se han entrevistado con los responsables de Sistemas, de Servicios y de Seguridad de Microsoft.
- **Visita a las instalaciones:** Se ha procedido a la visita presencial del centro de procesamiento de datos que Microsoft dispone en Madrid (Av. de la Industria, 15, 28108 Alcobendas, Madrid España). Este centro no había sido visitado en auditorías de certificación previas.
- **Presentación conclusiones:** en la última fase de la metodología, se ha procedido a la validación de la información y se han presentado a la Organización las conclusiones y observaciones derivadas del trabajo realizado.

1.7. CONCLUSIONES

Las principales conclusiones obtenidas de nuestro trabajo de revisión de las medidas y controles de seguridad conforme a la categoría Alta de los sistemas de información que soportan el servicio de Azure de Microsoft son las que se indican a continuación:

- a) Microsoft dispone de la preceptiva Política de Seguridad, un marco normativo de seguridad completo y actualizado y del proceso de organización e implantación de la seguridad a través de un sistema de gestión de seguridad de la información documentado, aprobado por su Dirección y certificado. Todo ello permite un proceso de mejora continua de la gestión de la seguridad conforme a lo establecido en los principios básicos y requisitos mínimos del Esquema Nacional de Seguridad.

- b) Existe una adecuada identificación y gestión de riesgos de los sistemas que soportan los servicios dentro del alcance detallados anteriormente, incluyendo la identificación de escenarios de riesgo, el análisis de las consecuencias y su probabilidad, y la evaluación de su aceptabilidad o inaceptabilidad para la Organización, según lo establecido en las medidas aplicables del Anexo II del Real Decreto 311/2022.
- c) Se cumplen de manera global las medidas de seguridad descritas en el Anexo II, sobre Medidas de Seguridad, en función de las condiciones de aplicación en cada caso.
- d) Las medidas y controles de seguridad de categoría Alta de aquellos aspectos de aplicación para los sistemas de información que soportan el servicio Azure de Microsoft, sus Sistemas de Información e instalaciones de tratamiento de datos cumplen con lo dispuesto en el Real Decreto 311/2022, del 3 de mayo, por el que se regula el Esquema Nacional de Seguridad.

No obstante, a lo anterior, en la comprobación de la adecuación de las medidas y controles de seguridad conforme de categoría Alta del Real Decreto 311/2022, del 3 de mayo, de aquellos aspectos de aplicación para los sistemas revisados, se han identificado dos observaciones que no comprometen las áreas del sistema de gestión definido en el ENS.

- e) Las observaciones se concretan en los siguientes aspectos:

Marco Operacional

- **Control de acceso**

Respecto al Mecanismo de autenticación (usuarios de la organización) - op.acc.6, se ha observado que:

B1) [Observación]: Por defecto en los servicios de Azure no se informa al usuario sobre sus obligaciones respecto al control de acceso y políticas de seguridad (no dispone de disclaimer) durante el proceso de autenticación. No obstante, se ha observado que el administrador del servicio del cliente puede configurarlo a través del Entra ID.

M1) [Observación]: No se informa al usuario cuando se conecta a los servicios de Azure del último acceso realizado al servicio. Para mitigar los riesgos de suplantación de identidad, Azure ofrece a los administradores del cliente herramientas de monitorización de accesos y otros reportes de accesos.

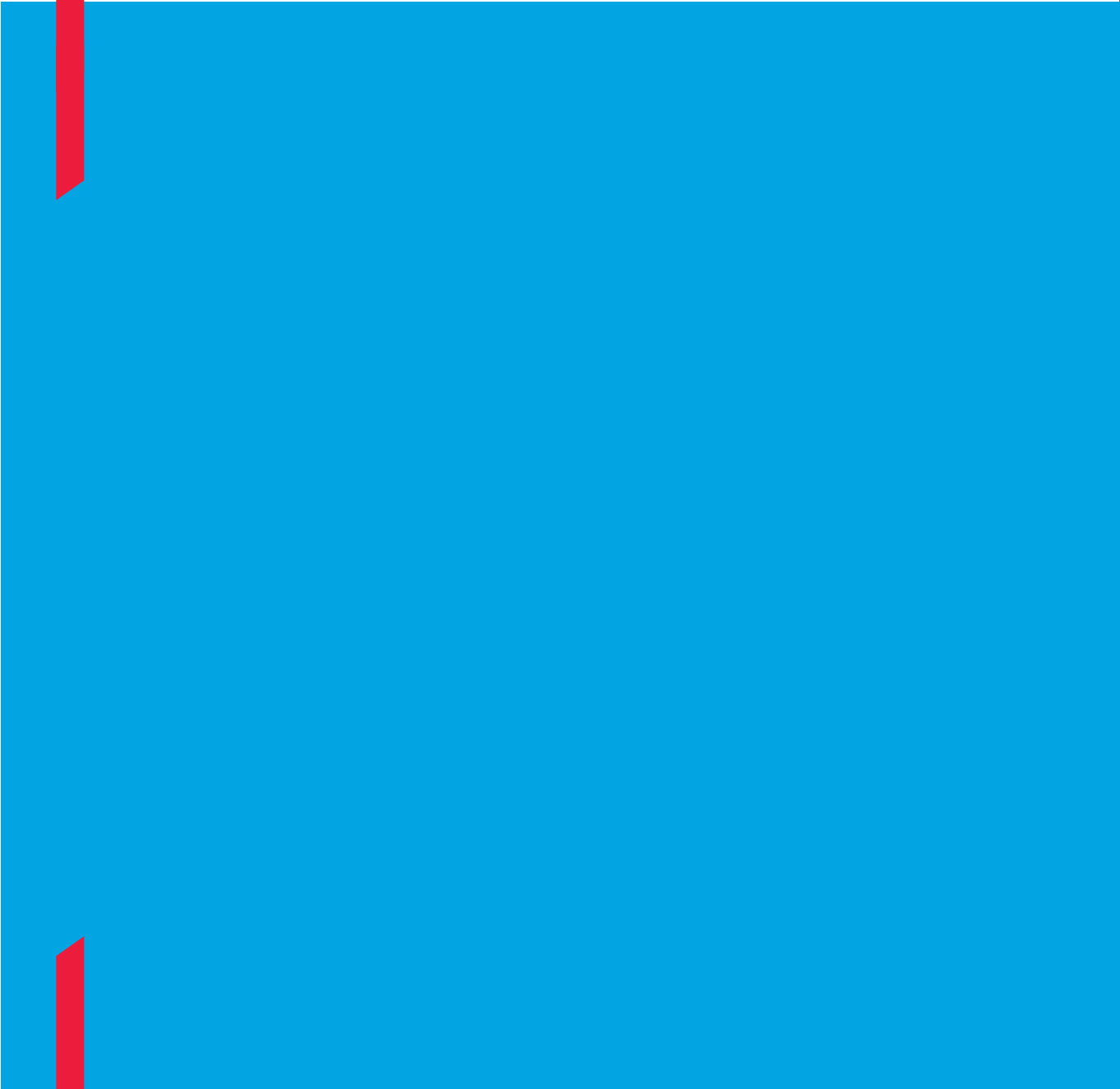
- f) El dictamen final del informe de auditoría es: **Favorable**

BDO Auditores, S.L.P.



Roger Pérez
Auditor jefe

Madrid, 22 de abril de 2024



RESUMEN DE LAS MEDIDAS DE SEGURIDAD

Informe de auditoría del ENS de los sistemas de información
que soportan el servicio Azure de Microsoft

Microsoft Corporation

2. RESUMEN DE LAS MEDIDAS DE SEGURIDAD

A modo de síntesis, las siguientes tablas indican el grado de cumplimiento en el ENS a categoría Alta en base a los requerimientos normativos establecidos.

Leyenda	✓ Cumple	✗ NC Mayor	✗ NC Menor	- No Aplica
---------	----------	------------	------------	-------------

MARCO ORGANIZATIVO

Categoría	Tipo	Responsable			Dimensión		
		Microsoft	Proveedor	Cliente	Básico	Medio	Alto
(org)	1 - Política de Seguridad	☒			✓	✓	✓
	2 - Normativa de seguridad	☒			✓	✓	✓
	3 - Procedimientos de seguridad	☒			✓	✓	✓
	4 - Proceso de autorización	☒			✓	✓	✓

MARCO OPERACIONAL

Leyenda	✓ Cumple	✗ NC Mayor	✗ NC Menor	- No Aplica
---------	----------	------------	------------	-------------

Categoría	Tipo	Responsable			Dimensión		
		Microsoft	Proveedor	Cliente	Básico	Medio	Alto
Planificación (op.pl)	1 - Análisis de Riesgos	☒			✓	✓	✓
	2 - Arquitectura de Seguridad	☒			✓	✓	✓
	3 - Adquisición de nuevos componentes	☒			✓	✓	✓
	4 - Dimensionamiento / gestión de la capacidad	☒			✓	✓	✓
	5 - Componentes certificados	☒			-	✓	✓
Control de acceso (op.acc)	1 - Identificación	☒		☒	✓	✓	✓
	2 - Requisitos de acceso	☒		☒	✓	✓	✓
	3 - Segregación de funciones y tareas	☒		☒	-	✓	✓
	4 - Proceso de gestión de derechos de acceso	☒		☒	✓	✓	✓
	5 - Mecanismo de autenticación (usuarios externos)	☒		☒	✓	✓	✓
	6 - Mecanismo de autenticación (usuarios de la organización)	☒		☒	✓	✓	✓
Explotación (op.exp)	1 - Inventario de activos	☒			✓	✓	✓
	2 - Configuración de seguridad	☒			✓	✓	✓
	3 - Gestión de la configuración de seguridad	☒			✓	✓	✓
	4 - Mantenimiento y actualizaciones de seguridad	☒			✓	✓	✓
	5 - Gestión de cambios	☒			-	✓	✓
	6 - Protección frente a código dañino	☒			✓	✓	✓
	7 - Gestión de incidentes	☒			✓	✓	✓
	8 - Registro de la actividad	☒		☒	✓	✓	✓
	9 - Registro de la gestión de incidentes	☒			✓	✓	✓

Categoría	Tipo	Responsable			Dimensión		
		Microsoft	Proveedor	Cliente	Básico	Medio	Alto
	10 - Protección de claves criptográficas	☒			✓	✓	✓
Servicios externos (op.ext)	1 - Contratación y acuerdos de nivel de servicioa	☒			-	✓	✓
	2 - Gestión diaria	☒			-	✓	✓
	3 - Protección de la cadena de suministro	☒			-	-	✓
	4 - Interconexión de sistemas				-	-	-
Servicios en la nube (op.nub)	1 - Protección de servicios en la nube	☒			✓	✓	✓
Continuidad del servicio (op.cont)	1 - Análisis del impacto	☒			-	✓	✓
	2 - Plan de continuidad	☒			-	-	✓
	3 - Pruebas periódicas	☒			-	-	✓
	4 - Medios alternativos	☒			-	-	✓
Monitorización del sistema (op.mon)	1 - Detección de intrusión	☒			✓	✓	✓
	2 - Sistema de métricas	☒			✓	✓	✓
	3 - Vigilancia	☒			✓	✓	✓

MEDIDAS DE PROTECCIÓN

Leyenda	✓ Cumple	✗ NC Mayor	✗ NC Menor	- No Aplica
---------	----------	------------	------------	-------------

Categoría	Tipo	Responsable			Dimensión		
		Microsoft	Proveedor	Cliente	Básico	Medio	Alto
Protección de las instalaciones e infraestructuras (mp.if)	1 - Áreas separadas y con control de acceso	☒	☒		✓	✓	✓
	2 - Identificación de las personas	☒	☒		✓	✓	✓
	3 - Acondicionamiento de los locales	☒	☒		✓	✓	✓
	4 - Energía eléctrica	☒	☒		✓	✓	✓
	5 - Protección frente a incendios	☒	☒		✓	✓	✓
	6 - Protección frente a inundaciones	☒	☒		-	✓	✓
	7 - Registro de entrada y salida de equipamiento	☒	☒		✓	✓	✓
Gestión del personal (mp.per)	1 - Caracterización del puesto de trabajo	☒			-	✓	✓
	2 - Deberes y obligaciones	☒			✓	✓	✓
	3 - Concienciación	☒			✓	✓	✓
	4 - Formación	☒			✓	✓	✓
Protección de los equipos (mp.eq)	1 - Puesto de trabajo despejado	☒			✓	✓	✓
	2 - Bloqueo de puesto de trabajo	☒			-	✓	✓
	3 - Protección de portátiles	☒			✓	✓	✓
	4 - Otros dispositivos conectados a la red	☒			✓	✓	✓
Protección de las comunicaciones (mp.com)	1 - Perímetro seguro	☒			✓	✓	✓
	2 - Protección de la confidencialidad	☒			✓	✓	✓
	3 - Protección de la integridad y de la autenticidad	☒			✓	✓	✓

Categoría	Tipo	Responsable			Dimensión		
		Microsoft	Proveedor	Cliente	Básico	Medio	Alto
	4 - Separación de flujos de información en la red	☒			-	✓	✓
Protección de los soportes de información (mp.si)	1 - Marcado de soportes	☒			-	✓	✓
	2 - Criptografía	☒			-	✓	✓
	3 - Custodia	☒			✓	✓	✓
	4 - Transporte	☒			✓	✓	✓
	5 - Borrado y destrucción	☒			✓	✓	✓
Protección de las aplicaciones inf. (mp.sw)	1 - Desarrollo de aplicaciones	☒			-	✓	✓
	2 - Aceptación y puesta en servicio	☒			✓	✓	✓
Protección de la información (mp.info)	1 - Datos personales	☒			✓	✓	✓
	2 - Calificación de la información	☒			-	✓	✓
	3 - Firma electrónica			☒	-	-	-
	4 - Sellos de tiempo	☒			-	-	✓
	5 - Limpieza de documentos	☒			✓	✓	✓
	6 - Copias de seguridad	☒		☒	✓	✓	✓
Protección de los servicios (mp.s)	1 - Protección del correo electrónico	☒			✓	✓	✓
	2 - Protección de servicios y aplicaciones web	☒			✓	✓	✓
	3 - Protección de la navegación web	☒			✓	✓	✓
	4 - Protección frente a la denegación de servicio	☒			-	✓	✓

BDO Auditores S.L.P., es una sociedad limitada española, y miembro de BDO International Limited, una compañía limitada por garantía del Reino Unido y forman parte de la red internacional BDO de empresas independientes asociadas.

BDO es la marca comercial utilizada por toda la red BDO y para todas sus firmas miembro.

Copyright © 2023. Todos los derechos reservados. Publicado en España.

bdo.es

bdo.global



Auditoría & Assurance | Advisory | Abogados | Outsourcing